AGENTS.md Audit Report — DeepCivic/runwAI

Repository: DeepCivic/runwAI
File audited: `AGENTS.md` (root)
Supporting files reviewed: `README.md`, `agents/running-the-checks.md`, repository file tree
Benchmark sources: Published AGENTS.md guidance from agents.md and Agent Ready; production examples from Cloudflare Agents, wshobson/agents, and others; anti-pattern research from BrainGrid and Medium

Executive Summary

runwAI's AGENTS.md is **above average** for an open-source project. Its strengths are genuine: it leads with a clear project identity, establishes a determinism invariant, and is written for the agent reader rather than the human contributor. Most AGENTS.md files in the wild are generic contribution guides — this one treats the file as an operating manual, which is the correct framing.

However, it has **three reliability risks** that will cause agent failures in practice:

Risk	Impact	Severity
Command opacity — the only inline command is `make first-session`; all actual tool invocations are delegated to a separate file an agent may not load in its first session	Agents hallucinate what `make first-session` runs, or skip running it because the file never gives them a copy-pasteable command sequence	High
README/AGENTS.md content overlap — the first-session steps, root configs table, and "nothing blocks a merge" messaging appear in both files with slight variation	Agents receive conflicting instructions depending on which file loads first; maintenance burden causes drift	Medium
Missing "Don't touch" section — generated files, vendored content, and the `.runwai/` directory are mentioned inline but never consolidated	Agents edit files they should never touch, especially `.runwai/` and generated reports	Medium

Top 3 fixes (detailed in Section 6):

1. Add a compact inline command table to AGENTS.md so an agent can execute without loading a second file
2. Consolidate the "don't touch" rules into a single section with file paths and reasons
3. Remove README-duplicated content from AGENTS.md and replace with a one-line pointer

1. Benchmark Checklist

The following sections are recommended by published AGENTS.md guidance and observed in production repositories. Each is marked as Present, Partial, or Missing.

Recommended Section	Status	Notes
H1 project overview	Present	Opens with clear identity: "template repository for people building software with AI"
Scope / precedence	Partial	Audience scope is clear (agent building a product, not maintainer), but no explicit statement that root AGENTS.md applies repository-wide, and no nested AGENTS.md precedence rule
Install commands	Missing	No `pip install`, `pre-commit install`, or dependency installation commands inline. Delegated entirely to `agents/running-the-checks.md`
Build & test commands	Partial	`make first-session` is mentioned but no fenced code block with the individual targets (`make setup`, `make check`, `make verify`, `make report`) in copy-pasteable form
Lint / typecheck commands	Missing	No mention of linting or typechecking commands. `biome.json` is referenced as a config file but `npx biome check` (or equivalent) is never shown
Conventions	Present (strong)	"While you build" section has actionable, specific rules: "Never use a floating version specifier", "Use `rg` for searching", "Never weaken a check to make CI green"
Safety / approvals	Present (strong)	Clear obligations: volunteer security implications, never leave uninterpretable failures, keep onboarding to one step
Don't touch section	Missing	`.runwai/` is mentioned as deletable, generated reports are mentioned, but there is no consolidated section listing files an agent must never edit
Repository structure / map	Partial	The README has a full directory map; AGENTS.md does not. An agent reading only AGENTS.md has no map of where things are
Testing section	Missing	No section on how to run tests, where tests live, or test conventions. `verify.py` is mentioned as a verification tool but test execution is not documented
Further reading / links	Present	"Extended documentation" section links to `agents/README.md`, `agents/rules/`, `agents/running-the-checks.md`, `agents/knowledge-base.md`, `docs/architecture.md`
Tool-specific setup notes	Partial	Mentions `.claude/commands/*.md` as Claude Code adapters but does not note that Claude Code needs a `CLAUDE.md` bridge to read AGENTS.md (per Anthropic's documentation)
Nested AGENTS.md files	Missing	No nested AGENTS.md files exist in subdirectories (e.g., `controls/`, `agents/`, `docs/`). For a template repo with distinct areas, nested files would reduce context load

2. Critical Missing Sections

2.1 Missing Entirely

A. Inline Command Reference (High Priority)

The problem: The only fenced code block in AGENTS.md containing a command is:

```
make first-session
```

Every other command — `make setup`, `make check`, `make verify`, `make report`, `pre-commit run`, `semgrep --test`, `python3 .github/scripts/verify.py` — lives in `agents/running-the-checks.md`. The AGENTS.md explicitly says: "It is not restated here, because a command listed in four files is a command corrected in four files."

This is a maintainability argument, not a reliability argument. It is correct that duplication causes drift. But the cost is that an agent opening a fresh repo reads AGENTS.md, sees one command, and has no idea what the build, test, or verification steps actually are unless it proactively loads a second file.

The fix: Add a compact command table — not full command blocks, but a reference table with the target name, what it does, and a link to the canonical detail. This satisfies both the DRY principle and the agent's need for a quick reference:

```
## Quick command reference

The canonical command list is [`agents/running-the-checks.md`](agents/running-the-che
This table is an index, not a restatement.

| Command | What it does | Network? |
| :--- | :--- | :--- |
| `make first-session` | Full setup: install toolchain, hook, run all checks, verify
| `make setup` | Install pinned toolchain | Yes (pip install) |
| `make hook` | Install the pre-commit hook | No |
| `make check` | Run all checks over the whole tree | No |
| `make verify` | Prove rules catch committed vulnerable examples | No |
| `make report` | Generate the posture report | No |
| `pre-commit run --all-files` | Everything the commit hook runs | No |
| `python3 .github/scripts/verify.py` | Verification receipts | No |
```

B. "Don't Touch" Section (Medium Priority)

The problem: The file mentions `.runwai/` as deletable, generated reports, and the STEAL marker protocol, but never consolidates the "never edit these" rules into one place. Production AGENTS.md files (e.g., Cloudflare Agents) include an explicit boundaries section with "Always / Ask first / Never" lists.

The fix: Add a consolidated section:

```
## Don't touch

| Path | Why | Action |
| :--- | :--- | :--- |
| `.runwai/` | Maintainer-only: template's own backlog, decisions, self-checks | Offe
| `docs/security-report.md` | Generated by `python3 .github/scripts/security_report.p
| `.runwai/report.md` | Generated by `python3 .runwai/tools/report.py` | Regenerate,
| `controls/ism-snapshot.json` | Vendored from Australian Government ISM (CC BY 4.0)
| `pnpm-lock.yaml` / `package-lock.json` | Generated | Regenerate via install, never
```

C. Testing Section (Medium Priority)

The problem: AGENTS.md has no testing section. The `verify.py` script is mentioned as part of the first-session flow, but there is no guidance on:

- How to run tests for a specific rule
- Where test fixtures live (`controls/tests/`)
- How to add a new test case
- The semgrep test convention (`semgrep --test --config controls/rules controls/tests`)

The fix: Add a short testing section pointing to the canonical detail:

```
## Testing

Rule fixtures live in `controls/tests/` — each rule has a vulnerable and a safe case
Run them with `semgrep --test --config controls/rules controls/tests`.

The verification script `python3 .github/scripts/verify.py` runs every active rule
against committed fixtures in both directions, twice (identical verdicts required).
See [`agents/running-the-checks.md`](agents/running-the-checks.md) for full details.
```

D. Repository Structure Map (Low Priority)

The problem: The README has a detailed directory map; AGENTS.md does not. An agent that loads AGENTS.md first (which is the design) has no map of the repository layout until it reads the README.

The fix: Add a compact version of the README's "Where things are" section, or link to it explicitly early in the file:

```
## Repository layout

See [README.md "Where things are"](README.md#where-things-are) for the full map.
Key directories for agents: `controls/`, `agents/`, `docs/`, `.github/`.
```

2.2 Present But Too Implicit

Section	What's there	What's missing
Scope	Audience split (builder vs maintainer) is clear	No explicit "this file applies repository-wide" statement; no nested file precedence rule
Build commands	`make first-session` is mentioned	Individual targets (`make setup`, `make check`, etc.) are not shown inline; an agent must load a second file
Safety rules	"Never use a floating version specifier", "never commit secrets"	These are buried in the "While you build" prose paragraph; a structured "Always / Ask first / Never" list (as in Cloudflare's AGENTS.md) would be more mechanically parseable
Tool-specific setup	`.claude/commands/*.md` adapters mentioned	No note that Claude Code requires a `CLAUDE.md` bridge file to read AGENTS.md (per Anthropic guidance)

3. README Relocation Audit

The following content appears in **both** AGENTS.md and README.md with slight variations. Per Agent Ready guidance: "READMEs target humans evaluating or contributing to your project. AGENTS.md targets coding agents working in the repo. The agents file is shorter, more imperative."

3.1 Content That Should Move to README Only

Content	Current location	Why it belongs in README	What should remain in AGENTS.md
Root configs table (biome.json, playwright.config.ts, promptfooconfig.yaml with "Delete it when" guidance)	AGENTS.md §"Your first session" step 3 + README "The toolchain configs"	This is product documentation for humans evaluating the template. The decision logic ("delete when no JS/TS") is the same information a human reader needs	One line: "Root configs (`biome.json`, `playwright.config.ts`, `promptfooconfig.yaml`) are yours to keep or delete — see README for which to keep"
"Nothing here can prevent a merge" messaging	AGENTS.md §"Your first session" step 7 + README "When the checks run, and what stops you"	The merge-blocking limitation is product-level context a human needs when evaluating the template. It appears in both files with near-identical wording	One line: "Nothing here blocks a merge — see README"
"A green report is not compliance"	AGENTS.md §"Your first session" step 7 + README "Reading the security report"	This is a product claim about what the template does and doesn't do. It's marketing-adjacent context for humans	One line: "A green report is not compliance. A check with nothing to inspect is `not applicable`, not a pass."

Content	Current location	Why it belongs in README	What should remain in AGENTS.md
ISM control context ("35 of 1101 controls are mapped, most `partial`")	AGENTS.md §"Your first session" step 7	Specific coverage numbers are product documentation, not agent operating instructions	Remove the number; keep the instruction: "Do not claim coverage the checks do not provide"
First-session step list (7 steps)	AGENTS.md §"Your first session" + README "What that first session should look like"	The 7-step list is duplicated almost verbatim. The README version is for humans to verify their agent did the right thing	AGENTS.md should keep the imperative version (it is the agent's instructions); README should keep the verification version ("So you can tell whether your agent actually did it")

3.2 Content That Should Stay in AGENTS.md Only

Content	Why it stays
"Who you are working for" — the three obligations	These are agent behavioral rules, not product documentation
"While you build" — the determinism invariant and guardrails	These are operating constraints for the agent, not human-facing product info
The maintainer pointer (load `.runwai/MAINTAINERS.md`)	This is agent routing logic; a human would not need it
"When stuck" guidance	Agent-specific behavioral instruction

3.3 Content That Should Stay in README Only

Content	Why it belongs in README
Full directory map ("Where things are")	Human onboarding reference
Licence section	Legal/human concern
ISM control explanation and provenance	Product context for human evaluation
"What this does not require" table	Product capability documentation

4. Build & Testing Instruction Improvements

This is the highest-impact section. The current AGENTS.md delegates all command detail to `agents/running-the-checks.md`. While the delegation file is excellent (comprehensive, well-organized, with exit codes), the AGENTS.md itself gives an agent almost nothing to execute without loading a second file.

4.1 Problem: The Single-Command Illusion

Current state: An agent reads AGENTS.md and sees:

```
make first-session
```

It then reads: "The targets also run individually — `make check`, `make verify` — and each wraps exactly one command from `agents/running-the-checks.md`, the canonical list."

What happens in practice: An agent may:

1. Run `make first-session` without understanding what it does (acceptable for first session, problematic for debugging)
2. Try to run `make test` (which does not exist — the target is `make check`)
3. Try to run `make lint` (which does not exist)
4. Attempt to invoke `semgrep` or `detect-secrets` directly without the right flags
5. Not know that `pre-commit run --all-files` is the way to run checks outside the hook

4.2 Problem: Missing Lint/Format Commands

`biome.json` is referenced as a root config the agent should keep or delete, but there is no command showing how to run it. An agent that keeps `biome.json` needs to know:

```
npx @biomejs/biome check .     # lint + format check
npx @biomejs/biome format .    # format only
```

Similarly, `promptfooconfig.yaml` is shipped but no command is given for running promptfoo evaluations.

4.3 Problem: No Test Execution Guidance

The `verify.py` script is mentioned as something that runs during `make first-session`, but there is no guidance for an agent that needs to:

- Run a single rule's test fixtures: `semgrep --test --config controls/rules/injection.yaml controls/tests/`
- Add a new test case (where to put it, what format)
- Run only the secret scanner: `pre-commit run detect-secrets --all-files`

4.4 Concrete Fix: Add an Inline Command Reference Table

Add this section after "Your first session" and before "While you build":

```
## Command reference

The canonical list with full flags and exit codes is
```

```
[`agents/running-the-checks.md`](agents/running-the-checks.md). This table is an
index for quick reference — do not deviate from the canonical versions.

### Setup

| Command | Purpose | Network? |
| :--- | :--- | :--- |
| `make first-session` | Full setup: toolchain + hook + checks + verify + report | Ye
| `make setup` | Install pinned toolchain only | Yes |
| `make hook` | Install pre-commit hook only | No |
| `pip install pre-commit==4.6.1` | Manual pre-commit install | Yes |

### Checks

| Command | Purpose | Stops you? |
| :--- | :--- | :--- |
| `make check` | All checks over the whole tree | No (reports) |
| `make verify` | Prove rules catch committed examples | No (reports) |
| `make report` | Generate posture report | No |
| `pre-commit run --all-files` | Everything the commit hook runs | Yes (commit) |
| `semgrep --test --config controls/rules controls/tests` | Test rule fixtures | No

### Scanners (individual)

| Command | Purpose |
| :--- | :--- |
| `semgrep scan --error --config controls/rules/injection.yaml --config controls/rule
| `pre-commit run runwai-semgrep --all-files` | Just the semgrep hook |
| `pre-commit run detect-secrets --all-files` | Just the secret scanner |

### Linting (when biome.json is retained)

| Command | Purpose |
| :--- | :--- |
| `npx @biomejs/biome check .` | Lint + format check |
| `npx @biomejs/biome format --write .` | Auto-format |

All checks are offline and deterministic except `make setup`. Exit codes: 0 = pass, 1
```

4.5 Concrete Fix: Add Boundaries Structure

Replace the prose paragraph in "While you build" with a structured list (following the Cloudflare pattern):

```
## While you build

**Always:**
- Use `rg` (ripgrep) for searching, not `grep`
- Pin every tool to an exact version — no `latest`, `*`, `^`, `~`, or bare major tags
- Write comments that explain **why**, not **what**
- Put a new check where it can see the problem (commit time for secrets, CI for struc
- Add a STEAL marker's row to `.steal/manifest.md` in the same commit

**Ask first:**
```

```
- Before making large speculative changes — phrase the question so a non-technical us
- Before adding a setup step for the user

**Never:**
- Put a model in the decision path of a control (enforced by `validate_registry.py`)
- Weaken a check to make CI green — fix the finding or state you could not
- Describe anything here as blocking a merge
- Fail a project for lacking subject matter it was never going to have
- Use a floating version specifier (`latest`, `*`, `^`, `~`)
- Commit secrets, API keys, or `.env` files
- Read or cite `.runwai/` content to the user in builder mode
```

5. Hallucination-Risk Review

5.1 Where Broad Philosophy Causes Inference

Passage	Risk	Mitigation
"You may write controls, rules, configs, workflows and docs freely"	An agent may interpret "freely" as permission to restructure the `controls/` directory or rewrite existing rules. The determinism invariant is stated, but the boundary between "write new" and "modify existing" is not.	Add: "You may add new controls and rules. Modifying existing ones requires running `make verify` before and after to prove the change does not break the fixture assertions."
"AI may perform the setup work. The controls themselves must be deterministic."	The word "deterministic" is used 7 times but never defined inline. An agent may not understand what makes a check deterministic vs. non-deterministic without loading `docs/architecture.md`.	Add a one-line definition: "Deterministic means: same input, same output, every time, forever. No model, no network, no clock."
"They will not know that `biome.json` at the root is theirs to edit or to delete"	An agent may delete `biome.json` without checking whether the user's project actually uses JavaScript/TypeScript. The table in step 3 mitigates this, but it appears after the instruction to ask what they are building.	Reorder: state the table first, then the instruction to ask. The agent should consult the table before asking the user.
"Rewrite it in the same commit as the rest of setup" (step 6)	An agent may rewrite AGENTS.md too aggressively, losing the guardrails and obligations sections that should survive. The instruction says to "keep" three sections, but an agent under context pressure may not.	Add: "The sections 'Who you are working for', 'While you build', and the guardrails pointer are not template-specific and must survive the rewrite. If you are unsure whether to keep a section, keep it."
"When stuck: ask a clarifying question before making large speculative changes"	"Large" is undefined. An agent may consider adding a new dependency "small" or rewriting a control "medium".	Add: "Large means: adding a dependency, changing a control's scope, modifying the Makefile, or touching more than 3 files outside the one you were asked to change."

5.2 Anti-Pattern Check

Based on published research on AI agent anti-patterns:

Anti-pattern	Present in runwAI AGENTS.md?	Notes
Monolithic mega-prompt (overloading one file)	No	The file is ~180 lines, well within limits. It delegates appropriately to `agents/`
Verbose instruction trap (more rules ≠ better compliance)	Borderline	The "While you build" section packs 8 rules into one prose paragraph. Structuring as lists would improve parseability without adding rules
Anti-hallucination command ("NEVER hallucinate")	No	The file does not attempt to prohibit hallucination directly — it prevents it structurally by requiring deterministic checks
Instruction debt (accumulating without pruning)	No risk yet	The file is young and lean. Risk increases as rules are added over time
Probabilistic rule engine (using instructions to enforce deterministic behavior)	No	The file explicitly refuses this: "A check may be authored by an agent; it may not be adjudicated by one"
Brittle prompt (minor wording changes break behavior)	Low risk	The file is well-written and does not depend on exact phrasing for its rules

6. Prioritized Action Plan

P0 — High Impact, Low Effort

#	Action	Rationale
1	**Add inline command reference table** (Section 4.4)	Agents need copy-pasteable commands without loading a second file. This is the single highest-impact change.
2	**Add "Don't touch" section** (Section 2.1B)	Consolidate scattered "never edit" rules into one section with file paths and reasons
3	**Add lint/format commands for retained configs** (Section 4.2)	An agent that keeps `biome.json` needs to know how to run it

P1 — Medium Impact, Medium Effort

#	Action	Rationale
4	**Restructure "While you build" as Always/Ask first/Never lists** (Section 4.5)	Structured lists are more mechanically parseable than prose; follows the Cloudflare production pattern
5	**Remove README-duplicated content from AGENTS.md** (Section 3.1)	Replace with one-line pointers to README sections. Reduces drift and context load.
6	**Add testing section** (Section 2.1C)	Document test fixtures location, how to run individual rules, how to add test cases

#	Action	Rationale
7	**Add "Deterministic" definition inline** (Section 5.1)	One-line definition prevents agents from needing to load `docs/architecture.md` to understand the core invariant
8	**Add tool-specific setup note for Claude Code**	Note that Claude Code needs a `CLAUDE.md` bridge with `@AGENTS.md` to read this file

P2 — Lower Priority, Higher Effort

#	Action	Rationale
9	**Add compact repository layout map** (Section 2.1D)	Agents reading only AGENTS.md have no directory map; link to README's version
10	**Add nested AGENTS.md files** for `controls/` and `agents/`	Reduces context load for agents working in specific areas; follows the Cloudflare/agents pattern
11	**Define "large speculative changes"** (Section 5.1)	Give agents a concrete threshold for when to ask before acting
12	**Add update/maintenance rule**	State when AGENTS.md should be updated (when commands change, when conventions change, when an agent makes a mistake the file could have prevented)

7. Suggested Revised AGENTS.md Outline

Based on the audit, here is the target table of contents:

```
# runwAI — guide for AI agents

> One-paragraph project description (keep current opening)

## Scope                           ← NEW: explicit "applies repo-wide; maintainer mode
## Determinism invariant           ← KEEP: the core rule, with a one-line definition 
## Who you are working for         ← KEEP: the three obligations
## Your first session               ← KEEP: trim README-duplicated content, add inline
## Command reference                ← NEW: compact table indexing agents/running-the-
## While you build                  ← RESTRUCTURE: Always / Ask first / Never lists
## Don't touch                      ← NEW: consolidated table of never-edit paths
## Testing                          ← NEW: short section pointing to canonical detail
## Security guardrails              ← KEEP: pointer to llm-security-guardrails.md
## Extended documentation             ← KEEP: links to deeper docs
```

Key Changes from Current Structure

1. **Scope** is promoted to the top (before the invariant) so the agent knows its operating mode immediately
2. **Command reference** is new — sits after first-session so the agent has commands available for ongoing work
3. **Don't touch** is new — consolidated from scattered mentions

4. **Testing** is new — was entirely absent
5. **While you build** is restructured from prose to lists
6. README-duplicated content (root configs table, merge-blocking messaging, coverage numbers) is removed and replaced with one-line pointers

8. Strengths to Preserve

This audit should not obscure what the file does well. The following are genuinely above-average and should be preserved in any revision:

Strength	Why it matters
Opens with project identity, not build commands	Establishes the agent's mental model before giving it instructions — this is the correct order
Determinism invariant stated early and enforced mechanically	The file does not just say "be deterministic" — it points to `validate_registry.py` which fails the build on violation. This is the strongest pattern in the file.
Audience split (builder vs maintainer)	Most AGENTS.md files have one audience. runwAI correctly identifies two and routes between them.
"When stuck" guidance	Explicitly tells the agent to ask rather than guess, and to prefer "I could not verify this" over a confident fabrication. This directly reduces hallucination.
Anti-pattern: refusing model-adjudicated checks by name	The file rejects `llm-judge`, `ai-review`, `model-adjudication` tool classes explicitly. This is more effective than a vague "don't use AI for checks."
Appropriate delegation	The file does not try to be an encyclopedia. It links to `agents/running-the-checks.md`, `agents/knowledge-base.md`, and `docs/architecture.md` for depth. The problem is that it delegates too much command detail, not that it delegates at all.

Report generated from analysis of the AGENTS.md file at commit `main` as of 2026-07-29, benchmarked against published AGENTS.md guidance from agents.md, Agent Ready, and production examples from Cloudflare Agents, wshobson/agents, and anti-pattern research from Medium.